

THE FUTURIST'S STRATEGY CONE™

A Human-Controlled Governance Framework
for Agentic AI in Internal Audit

4 STAGES: Risk → Audit → Evidence → Reporting



RISK

Identify, assess and prioritize AI risks across processes and data.



AUDIT

Design and perform intelligent audits with AI oversight and human judgment.



EVIDENCE

Capture immutable, traceable and verifiable audit evidence.



REPORTING

Deliver meaningful insights for assurance and decision-making.



Agentic AI
Audit Leader



Predictive
Intelligence



Real-time
Assurance



Stronger
Governance

ADNAN SHAMIM

AGENTIC AI LEADER
INTERNAL AUDIT & AI GOVERNANCE PROFESSIONAL



EMAIL

ad.shamim1985@gmail.com



MOBILE

03138224669



CREATOR OF
**THE FUTURIST'S
STRATEGY CONE™**



Designed for Boards, CFOs & CAEs
to Govern Agentic AI with Confidence



AI Enhances Capability,
Humans Maintain Accountability.



Explore the
Framework
**Scan to
learn more.**



ad.shamim1985@gmail.com



03138224669



linkedin.com/in/
adnan-shamim-802a6622b



DM **"CONE"** for Framework



**THE HARDEST AGENTIC AI
GOVERNANCE QUESTION ISN'T "CAN AI
DO IT?"**

**IT'S "UNDER WHAT AUTHORITY
MAY AI DO IT?"**

That distinction becomes critical when AI moves beyond generating recommendations and begins to **take actions, make decisions, delegate tasks, or coordinate with other agents.**

Because:

AI CAPABILITY $\neq$ AI AUTHORITY

An agent may be technically capable of performing an action.

But technical capability does not, by itself, establish:

authorization, acceptable risk, decision rights, control requirements, or accountability.

Technical enablement is not governance authorization.

A workflow or API may technically permit an action without the organization having approved that action as an appropriate exercise of agent authority.

That is where governance begins.



THE FUTURIST'S STRATEGY CONE™

My framework treats Agentic AI governance as a **risk-based, lifecycle control architecture**:

**RISK → AUTHORITY →
BOUNDARY → RUNTIME
CONTROL → EVIDENCE →
INTERVENTION →
RECALIBRATION**

This does **not** mean every AI activity requires human approval.

It means autonomy should be **proportionate to risk, explicitly authorized, operationally bounded, and subject to appropriate oversight.**

1 RISK COMES BEFORE AUTONOMY

Before granting an agent authority, establish:

What could go wrong?

Who could be affected?

How significant could the impact be?

How reversible is the action?

What regulatory, financial, operational, or reputational exposure could arise?

Then determine the appropriate level of autonomy and control.

Greater potential impact → stronger and proportionate governance requirements.

Autonomy should be determined by **risk and approved authority**, not simply by technical capability.

2 AUTHORITY MUST BE EXPLICIT

An agent should not acquire authority merely because a workflow, tool, or API makes an action technically possible.

Governance should establish:

What the agent MAY do.

What it MAY recommend.

What requires escalation.

What it MUST NOT do.

Who remains accountable for the resulting business decision or outcome.

****Capability creates possibility.**

Authorization creates permission.**

They are not the same thing.

3 DECISION BOUNDARIES MUST BE OPERATIONAL

A boundary that exists only in a policy document is not enough.

Where appropriate, it should translate into controls such as:

**Permissions → thresholds →
segregation → escalation →
intervention → logging**

And the boundary should be **specific enough to test.**

For example:

What happens when confidence falls below the approved threshold?

What happens when a transaction exceeds an authorized limit?

What happens when an agent attempts an action outside its assigned role?

What happens when an agent delegates beyond its permitted authority?

If those answers are unclear:

THE GOVERNANCE BOUNDARY IS NOT OPERATIONALLY COMPLETE.

4 HUMAN OVERSIGHT MUST BE EFFECTIVE

Human oversight does **not** mean placing a person in front of every AI decision.

Where human intervention is required, the authorized person should have:

**Authority + Relevant Information +
Context + Ability to Intervene**

A human who can only click “**Approve**” without meaningful ability to challenge, modify, reject, or stop an action may create:

APPROVAL THEATRE

The presence of a human is not, by itself, evidence of effective human control.

5 MATERIAL ACTIONS NEED TRACEABLE EVIDENCE

For material or consequential AI-enabled activities, the organization should be able to reconstruct the relevant decision chain:

**Agent → Authority → Boundary →
Inputs/Evidence → Action →
Exception → Human Intervention
→ Outcome**

The objective is not indiscriminate logging of every AI interaction.

It is **proportionate traceability** sufficient to support:

Accountability.

Oversight.

Investigation.

Control testing.

Auditability.

The final output is only part of the story.

A sufficiently complete decision chain makes accountability reconstructable.

6 GOVERNANCE MUST ADAPT WHEN RISK CHANGES

Initial approval is not the end of governance.

The risk profile can change because of:

- Model or agent behaviour
- Data-quality deterioration
- Regulatory or policy changes
- Changes in risk appetite
- Operating conditions
- Exception patterns
- Human override trends
- Unexpected agent-to-agent behaviour

When material conditions change:

**REASSESS → RECALIBRATE →
REAUTHORIZE WHERE REQUIRED**

Governance therefore becomes a **lifecycle discipline**, not a one-time approval exercise.

7 FAILURE CONDITIONS MUST BE DEFINED BEFORE FAILURE

Responsible Agentic AI should not depend on the assumption that an agent will always operate within expected conditions.

The organization should define appropriate responses to relevant boundary breaches, material uncertainty, control failures, or other risk triggers.

Depending on the risk and control design:

**CONSTRAIN → ESCALATE →
SUSPEND → FAIL SAFELY**

These are **not universal mandatory steps or a fixed sequence**.

They are risk-based control responses that should be predefined by the organization.



THE PRACTICAL GOVERNANCE TEST

Before granting an AI agent autonomous authority, ask:

- 1. What risk does it create?**
- 2. What authority has been granted?**
- 3. What is the decision boundary?**
- 4. How is that boundary enforced?**
- 5. What evidence is required?**
- 6. When is human intervention required?**
- 7. Who owns the business outcome?**
- 8. What happens when the risk or boundary changes?**

If these questions cannot be answered clearly:

YOU MAY HAVE AI CAPABILITY.

**YOU DO NOT YET HAVE
GOVERNED AUTONOMY.**

THE CORE PRINCIPLE

AI Enhances Capability. Humans Maintain Accountability.

The objective is neither:

✗ Human approval everywhere

nor:

✗ AI autonomy everywhere

It is:

THE RIGHT AUTONOMY

FOR THE RIGHT RISK

WITHIN THE RIGHT AUTHORITY

INSIDE THE RIGHT BOUNDARY

WITH THE RIGHT CONTROLS

WITH SUFFICIENT EVIDENCE

**AND THE RIGHT INTERVENTION
MECHANISM**

That is the shift:

Capability → Authority

Policy → Operational Control

Static Approval → Lifecycle Governance

Human Presence → Human Authority

Output → Traceable Evidence

Monitoring → Adaptive Recalibration

THE REAL AGENTIC AI GOVERNANCE QUESTION

Not:

“Can AI make this decision?”

But:

“Is AI authorized to make this decision, at this level of risk, within this boundary, under these conditions—and can the organization demonstrate what happened if those conditions change?”

That is the difference between:

AI AUTONOMY

and

**GOVERNED
AUTONOMY.**

THE FUTURIST'S STRATEGY CONE™

v7.0

*An independent framework for
Responsible Agentic AI Adoption.*

THE FUTURIST'S STRATEGY CONE™

Reimagining Internal Audit for the Age of Agentic AI



By **Adnan Shamim**